

Ninthgreen

Rails 5.0.7.2 / Ruby 2.6.6 club-booking estate • one repo

SHA 6b4d2a5 • 15 August 2026 • Nestor Pestelos

Sample only.

EXECUTIVE SUMMARY

Members book classes, groups, dining, tee times, and events. The app still boots. The stack is past official support. Join, book, and mail go through a background worker. Cross-site request forgery protection is commented out.

FIX FIRST

- Turn request-forgery protection back on.
- Run the job worker next to the web process. Join and book enqueue mail.
- Keep the current Ruby and Rails pins. Do not mass-upgrade the lockfile.

LEAVE

- The leftover seed after the demo users.
- Old skin classes on events, tee times, and group show.
- Club timezone hardcoded to one zone.

Decision: pin-and-run. A version climb is a later fixed-scope modernization sprint, not this week.

SCOPE AND METHOD

One primary repository at SHA `6b4d2a5`. Read-only. Local compose, not staging. No production traffic. Case-study intake, not a client questionnaire.

AREA	RESULT
Architecture	Reviewed. One app. Person STI. None above Low.
Test trust	Reviewed. Estate integration tests exist. Full suite not re-run. None above Low this pass.
Hot paths	Reviewed. Clinic book, dining reserve, group join enqueue jobs. See High: worker.
Dependency health	Reviewed. Ruby 2.6.6 / Rails 5.0.7.2. High: past support.
Error handling	Reviewed. High: forgery protection off.
Deploy basics	Reviewed. Procfile web + worker. Worker is load-bearing.

Out of scope: penetration test, compliance certificate, a second service, ongoing monitoring. Member and tax-roll dumps in the tree were not used as evidence.

FINDINGS

HIGH Request-forgery protection is off

`app/controllers/application_controller.rb` comments out `protect_from_forgery`. A TODO says to put it back.

IMPACT — Book, join, and reserve posts have no Rails CSRF check.

FIX DIRECTION — Restore `protect_from_forgery with: :exception`. Recheck the mobile calendar exceptions in `app/controllers/calendar/app_controller.rb`.

HIGH Join, book, and mail need the job worker

`config/application.rb` sets the Active Job adapter to Sidekiq. Creating a group membership calls `deliver_later`. Clinic book and dining reserve do the same.

IMPACT — Without Redis and a worker process, join and book can error or drop mail.

FIX DIRECTION — Run the `worker` process from `Procfile` next to `web`. Do not create memberships in seed without skipping that callback.

HIGH Runtime is past official support

Ruby 2.6.6 (`Gemfile`, `.ruby-version`). Rails 5.0.7.2 (`Gemfile.lock`).

IMPACT — No official security patches. That is age, not a counted advisory list.

FIX DIRECTION — Stay pinned until a planned climb. Do not treat lockfile noise as a product upgrade.

MEDIUM Leftover seed after the demo block

`db/seeds.rb` creates demo users, then more people and groups. Adding members fires the join callback.

IMPACT — A full `db:seed` is not a safe one-shot.

FIX DIRECTION — Keep a narrow demo path. Do not run the rest.

MEDIUM Old skin classes on later surfaces

`app/views/events/index.html.erb` and the tee-time and group-show templates still use the old class set.

IMPACT — Those pages look broken if the old CSS engine is gone.

FIX DIRECTION — Restyle when a buyer cares. Not this week's operability.

LOW

Club timezone is one hard-coded zone

`TimezoneMonitor#club_time_zone` returns a single zone. Clinics, tee times, and several jobs repeat that string.

IMPACT — An operator in another zone sees the wrong calendar day.

FIX DIRECTION — One config value. Leave until geography changes.

ROADMAP

1. **This week (S)**. Restore CSRF. Run web and worker. Keep demo seed only.
2. **Before any Rails minor (M)**. Run the estate test pack. List gems that block 5.1.
3. **Later sprint (L)**. Ruby, then Rails. Not a lockfile sweep.
4. **Do not**. Mass-upgrade gems. Restore the old CSS engine. Publish this tree.

ASSUMPTIONS AND LIMITS

- Local compose. Not their staging.
- No production traffic.
- Security here is posture and dependency age, not a pentest and not an advisory count.
- In-tree member and tax-roll files were not opened as evidence.
- The club name on this page is fictional.